COMPTIA SECURITY+ SY0-701 | DOMAIN 2 · THREATS, VULNERABILITIES, AND MITIGATIONS (22%)

Security+ 2.3 · Supply Chain Vulnerabilities

Mestre CyberSec · **Lesson 2.3 — Supply Chain Vulnerabilities** (9:12) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Atacar o ELO que tu confias: software comprometido (SolarWinds), componente de terceiros, chip de hardware malicioso, library de código (npm/pip), open-source package sem dono claro. O atacante injeta código no CANAL CONFIÁVEL — todo mundo baixa espalha pra ele. Defesa: SBOM (lis

💡 Key Exam Highlights & Critical Concepts

- Supply chain: o atacante usa o CANAL CONFIÁVEL pra entrar
- SolarWinds: o caso clássico (18k empresas)
- SBOM = Software Bill of Materials — lista de componentes do software

🎯 Exam Tips & Typical CompTIA Scenarios

- 'list of software components' = SBOM
- 'checks dependencies for known vulnerabilities' = SCA

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 2.3 — Supply Chain Vulnerabilities)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Supply Chain Attack (N/A)

An attack that compromises a trusted vendor, supplier, or distribution channel to deliver malicious code or hardware to downstream customers.

⚠️ ***Exam Trap:*** *Lembre-se: o atacante não invade você diretamente; ele envenena o canal confiável que você já confia.*

• SolarWinds Attack (N/A)

A notable supply chain attack where threat actors compromised SolarWinds Orion software updates to distribute malware to about 18,000 organizations.

⚠️ ***Exam Trap:*** *Se a prova citar atualização de software confiável usada para espalhar backdoor, pense em SolarWinds.*

• Software Bill of Materials (SBOM)

A machine-readable inventory of all software components, libraries, and dependencies in a product, used to identify and manage supply chain risk.

⚠️ ***Exam Trap:*** *'List of software components' na prova = SBOM. Não confunda com SCA, que verifica vulnerabilidades.*

• Software Composition Analysis (SCA)

An automated tool or process that examines software dependencies and components for known vulnerabilities, license issues, and outdated libraries.

⚠️ ***Exam Trap:*** *'Checks dependencies for known vulnerabilities' = SCA. SBOM é a lista; SCA é a análise.*

• Third-Party Component (N/A)

Any external library, module, SDK, or service integrated into an application, introducing risk if it is vulnerable, malicious, or unsupported.

⚠️ ***Exam Trap:*** *Componente de terceiros amplia a superfície de ataque; a organização ainda é responsável pelo risco.*

• Malicious Hardware Chip (N/A)

A hardware implant or counterfeit component inserted during manufacturing or distribution that can create backdoors, exfiltrate data, or disable a device.

⚠️ ***Exam Trap:*** *Ameaça de cadeia de suprimentos de hardware: chip malicioso é difícil de detectar e pode vir de fornecedor comprometido.*

• Open-Source Package Risk (N/A)

Risk from using public open-source packages that may be unmaintained, lack a clear owner, or be vulnerable to typosquatting or dependency confusion.

⚠️ ***Exam Trap:*** *Pacote open-source sem dono claro ou desatualizado é vulnerabilidade de cadeia de suprimentos; nem todo código público é seguro.*

• Trusted Channel (N/A)

A legitimate communication or update path, such as vendor updates or app stores, that attackers abuse to deliver malicious content because users trust it.

⚠️ ***Exam Trap:*** *Frase-chave: 'atacante injeta código no canal confiável'. A defesa deve validar integridade mesmo em canais confiáveis.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Cadeia de Suprimentos de Software & Fornecedores Terceirizados

🏠 **Real-World Analogy:** It is like buying a cake from an award-winning bakery, but the third-party supplier delivering the flour had poison mixed into the mill. Even though the bakery itself is spotless, every single cake leaves the oven contaminated from the factory floor.

🔍 **Root Cause & Background:** Enterprises do not build all software from scratch; they depend on third-party code and automated vendor updates (e.g. SolarWinds). Compromising the trusted vendor automatically compromises thousands of downstream clients.

🛡️ **GRC Auditor Perspective:** Enforce Third-Party Risk Management (TPRM), verify vendor SOC 2 compliance reports, and mandate SBOM (Software Bill of Materials) with cryptographic hash integrity verification on all updates.

⚠️ **How CompTIA Tests This:** Trigger: "compromised software update pushed by a trusted vendor to all enterprise clients" -> Supply Chain Attack.

📌 SBOM (Software Bill of Materials) & Hardware Tampering

🏠 **Real-World Analogy:** An SBOM is the nutritional ingredient list on a cereal box, detailing every dye and preservative inside. Hardware tampering is like an operative intercepting a delivery van to solder a hidden surveillance microchip onto a server motherboard before it reaches your datacenter.

🔍 **Root Cause & Background:** Lack of transparency regarding subcomponents and unverified supply chain custody during hardware transit.

🛡️ **GRC Auditor Perspective:** Require tamper-evident seal physical inspections at intake and mandate SBOM cataloging for all approved corporate software.

⚠️ **How CompTIA Tests This:** Trigger: "formal inventory listing all open-source libraries, modules, and components inside a software package" -> SBOM (Software Bill of Materials).

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Attacker compromises the build pipeline of a trusted vendor to push malicious updates downstream	**Supply Chain Attack**
Formal inventory cataloging every third-party component and dependency inside software	**SBOM**
Spy microchip physically soldered onto a network appliance while in transit from factory	**Hardware Tampering**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A mid-size company's IT staff installed a routine update for its enterprise network monitoring platform, downloaded from the vendor's own update server and signed with the vendor's valid code-signing certificate. Months later, investigators confirmed that the vendor's build pipeline had been compromised and the update contained a backdoor that beaconed to an external server. Which factor made this supply chain attack effective against the company's existing anti-malware controls?

A) The payload was compressed with a commercial packer that engines do not inspect inside trusted installers.

B) The malicious code arrived inside an update digitally signed by the trusted vendor, so trust, hash, and reputation checks all passed.

C) The update disabled endpoint logging before installing the payload, preventing any record of the installation.

D) The attack relied on a hardware implant in the vendor's server, so no network traffic was generated.

QUESTION 2 · EXAM SCENARIO

A healthcare software manufacturer must now answer customer and regulator questions about every open-source and third-party component embedded in its product, including exact versions and transitive dependencies. Which deliverable BEST satisfies this requirement?

A) A software bill of materials (SBOM) generated for each release and refreshed with every build.

B) A penetration test report covering the compiled application and its exposed APIs.

C) A vulnerability scan of the production servers that host the application.

D) An asset inventory listing servers, endpoints, and network devices in the corporate environment.

QUESTION 3 · EXAM SCENARIO

During a code review, a developer notices that the team's application pulls in dozens of third-party packages, several of which bring their own dependencies. Management wants an automated way to identify known vulnerable versions and license conflicts in these components on every build. Which solution BEST meets the requirement?

A) Runtime application self-protection (RASP) agents installed on production hosts.

B) Static application security testing (SAST) configured to scan only the team's original source code.

C) Software composition analysis (SCA) integrated into the CI/CD pipeline.

D) File integrity monitoring (FIM) on the build server's operating system files.

QUESTION 4 · EXAM SCENARIO

After a security audit, an organization learns that several of its core switches were purchased from a third-party broker rather than an authorized reseller, and that the firmware on those devices does not match the vendor's published image hashes. Which action BEST reduces this hardware supply chain risk going forward?

A) Enable port security and 802.1X on all switch ports.

B) Procure network hardware only through authorized channels and verify vendor-signed firmware hashes before deployment.

C) Move all management traffic to an out-of-band network protected by ACLs.

D) Deploy a network access control (NAC) solution to profile connected endpoints.

QUESTION 5 · EXAM SCENARIO

A developer needs a popular Python HTTP library and installs a package whose name differs by one character from the legitimate one. The package's setup script silently exfiltrates environment variables, including CI/CD tokens, from the build server. Which control BEST prevents this class of attack?

A) Enforcing a curated internal package repository with an allowlist of approved packages and locked dependency versions.

B) Running the build server in a container with a read-only root filesystem.

C) Requiring multi-factor authentication for all developer accounts.

D) Enabling verbose logging of all outbound DNS queries from the build server.

QUESTION 6 · EXAM SCENARIO

An attacker compromises a developer's credentials and pushes a malicious commit that survives peer review because the change is hidden inside an obfuscated build script. The resulting artifact is deployed to customers as a normal release. Which control BEST limits the impact of an attacker who has already reached the build pipeline?

A) Requiring signed commits and cryptographically signing release artifacts with a build-only key that developers cannot access.

B) Increasing the frequency of automated dependency updates.

C) Adding a web application firewall in front of the customer-facing portal.

D) Restricting developer laptops to the corporate VLAN.

QUESTION 7 · EXAM SCENARIO

A company plans to onboard a cloud-based payroll provider that will process employee personally identifiable information. Before signing the contract, the security team must determine whether the provider's controls are adequate. Which activity BEST supports this decision?

A) Running an external vulnerability scan against the provider's public login page.

B) Reviewing the provider's independent audit report (for example, a SOC 2 Type II) and completing a vendor risk assessment questionnaire.

C) Requesting the provider's marketing whitepaper and its list of data center locations.

D) Testing the provider's disaster recovery by launching a simulated outage against its production API.

QUESTION 8 · EXAM SCENARIO

A national CERT advisory warns that a widely used open-source logging library was backdoored in a specific release published two weeks ago. A security analyst must determine which internal applications are exposed. Which action should the analyst take FIRST?

A) Block all outbound traffic from the affected business unit.

B) Query the SBOM and SCA inventory to identify which applications and container images include the backdoored version.

C) Notify all customers that their data may have been breached.

D) Rebuild every server in the data center from a golden image.

QUESTION 9 · EXAM SCENARIO

A payment application depends on an open-source library whose last release was four years ago; the original maintainer is unreachable and no successor project exists. Which action BEST addresses the long-term supply chain risk of this component?

A) Accept the risk, because the library's code has not changed and therefore no new vulnerabilities can appear.

B) Replace the library with a maintained alternative, or fork and maintain the code internally with ongoing vulnerability monitoring.

C) Add a web application firewall rule to block attacks targeting the library.

D) Move the application to a different cloud provider with a stronger security posture.

QUESTION 10 · EXAM SCENARIO

New workstations arrive from a supplier with a modified firmware image, and an implanted chip initiates an outbound connection at boot before the operating system loads. Which control BEST helps the organization detect this type of tampering?

A) TPM-based measured boot with remote attestation of boot measurements.

B) Host-based antivirus with daily signature updates.

C) Application allowlisting enforced on the endpoint.

D) A data loss prevention (DLP) agent that inspects files leaving the workstation.

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option B — The malicious code arrived inside an update digitally signed by the trusted vendor, so trust, hash, and reputation checks all passed.

The essence of a trusted-channel supply chain attack is that the malicious payload is delivered inside something the organization already trusts. Because the update was signed with the vendor's legitimate code-signing certificate, signature verification, hash comparison, and reputation checks all succeeded, and no anti-malware signature existed for the implant. This is the SolarWinds pattern: compromise the vendor's build or distribution pipeline once, and every downstream customer installs the implant voluntarily. Packing, log tampering, or hardware implants describe other techniques and are not what made this attack succeed.

Question 2: Option A — A software bill of materials (SBOM) generated for each release and refreshed with every build.

An SBOM is a formal, machine-readable inventory of the components, libraries, and versions that make up a software product, including transitive dependencies. It is the artifact that lets the manufacturer (and its customers) rapidly answer the question of what is inside a release and whether a newly disclosed vulnerability applies. Penetration tests, host vulnerability scans, and infrastructure asset inventories describe environments or test results, not the composition of the software itself.

Question 3: Option C — Software composition analysis (SCA) integrated into the CI/CD pipeline.

SCA tools analyze manifests, lockfiles, and dependency trees to inventory third-party and open-source components, correlate them with vulnerability databases, and flag license obligations. Running SCA in the pipeline catches vulnerable or non-compliant dependencies before the build is released. SAST examines the team's own source code (not third-party binaries), RASP protects at runtime in production, and FIM detects unauthorized file changes rather than component risk.

Question 4: Option B — Procure network hardware only through authorized channels and verify vendor-signed firmware hashes before deployment.

Counterfeit or tampered hardware and unauthorized firmware are supply chain integrity problems that must be addressed at the source of acquisition. Buying only from authorized distributors and validating vendor-signed firmware against published hashes ensures the device was not modified between the factory and the rack. Port security, out-of-band management, and NAC are valuable hardening controls, but none of them detect or prevent an implant or modified firmware already present in the device.

Question 5: Option A — Enforcing a curated internal package repository with an allowlist of approved packages and locked dependency versions.

This is typosquatting (a form of open-source package supply chain attack). A curated internal registry with an allowlist and pinned, integrity-checked versions prevents unvetted packages from entering the build at all, which is the only option that stops the malicious install rather than merely observing or limiting it. A read-only root filesystem does not stop a setup script from reading environment variables and sending them out, MFA does not apply to a package manager pulling a dependency, and DNS logging only provides detection after the tokens have already left.

Question 6: Option A — Requiring signed commits and cryptographically signing release artifacts with a build-only key that developers cannot access.

Once an adversary is inside the pipeline, the key defense is to make unauthorized artifacts detectable and unusable downstream. Commit signing ties changes to verified identities, and signing release artifacts with a build-only key that developers cannot reach means a tampered build cannot be presented as an authentic vendor release, because provenance attestation will fail. Dependency update frequency, a WAF, and VLAN restrictions do not address code integrity or release provenance in the build chain.

Question 7: Option B — Reviewing the provider's independent audit report (for example, a SOC 2 Type II) and completing a vendor risk assessment questionnaire.

Third-party risk management for a vendor handling sensitive data relies on evidence of the provider's control environment. A SOC 2 Type II report covers the design and operating effectiveness of controls over a period of time, and a structured security questionnaire fills the gaps that the report does not address (data handling, breach notification, subcontractors). Scanning only a login page tests almost nothing, marketing material is not assurance, and deliberately disrupting a provider's production API is unethical and likely illegal.

Question 8: Option B — Query the SBOM and SCA inventory to identify which applications and container images include the backdoored version.

The first step in responding to a compromised third-party component is scoping: determining which systems actually contain the affected version. An SBOM or SCA inventory answers that question quickly and accurately, so remediation, containment, and notification can be targeted. Blanket network blocks, blanket customer notifications, and mass rebuilds are disruptive, expensive, and premature actions taken before exposure is known.

Question 9: Option B — Replace the library with a maintained alternative, or fork and maintain the code internally with ongoing vulnerability monitoring.

An unmaintained, ownerless open-source package is a supply chain risk because no one patches it, and because an abandoned package name or repository account can be taken over and republished with malicious code. The durable fix is to eliminate the dependency by migrating to a maintained library, or to internalize the risk by forking and maintaining the code with continuous vulnerability monitoring and patching. Unchanged code can still be exploited through newly discovered flaws, and WAF rules or a cloud migration do not address an unpatched component inside the application.

Question 10: Option A — TPM-based measured boot with remote attestation of boot measurements.

A hardware or firmware implant that acts before the OS loads operates below the visibility of any host-based software control. Measured boot records cryptographic hashes of each boot stage into the TPM, and remote attestation compares those measurements against known-good values, so a modified firmware image produces a detectable mismatch. Antivirus, allowlisting, and DLP all run after the operating system is up and cannot see pre-boot activity or altered firmware.